

Informe OCTAVE: indicadores y métricas de ciberseguridad con foco nacional en España (tendencias 2025-2026)

Resumen ejecutivo

El marco OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation) nació como metodología auto-dirigida para que las organizaciones identificaran activos críticos, amenazas, vulnerabilidades y diseñaran estrategias de protección. Con sus derivadas OCTAVE Allegro y OCTAVE FORTE, ha evolucionado hacia un enfoque más ligero, centrado en activos de información y alineado con gobierno corporativo y Enterprise Risk Management (ERM).

Desde 2025, la conversación internacional sobre indicadores de ciberseguridad se ha desplazado desde el "checklist de controles" hacia métricas de madurez, resultados (incidentes, daños, resiliencia) y, cada vez más, hacia la medición de la incertidumbre en el riesgo cibernético. En paralelo, España ha consolidado un ecosistema de indicadores nacionales —Plan Nacional de Ciberseguridad, Esquema Nacional de Seguridad (ENS), informes de INCIBE, posición en índices internacionales— que ofrece un terreno fértil para adaptar OCTAVE a una escala territorial y de país.

Este informe propone una lectura "nacional" de OCTAVE: cómo reinterpretar sus criterios de impacto, probabilidad y criticidad a nivel de país, dialogando con marcos europeos como NIS2, el NIS360 de ENISA y el EU-Cybersecurity Index, así como con la agenda de medición de la OCDE y el ITU Global Cybersecurity Index. Culmina con un catálogo de indicadores OCTAVE para España y con baterías de preguntas de encuesta —y respuestas posibles— pensadas para que los CISOs de operadores esenciales, reguladores y estrategias puedan conversar con datos... y con un mínimo de sentido del humor.

1. El marco OCTAVE y su lógica de indicadores

1.1. OCTAVE clásico: activos, amenazas, vulnerabilidades e indicadores de riesgo

El OCTAVE original, definido por el Software Engineering Institute (SEI) de Carnegie Mellon a finales de los noventa, es un marco de evaluación de riesgos de seguridad de la información auto-dirigido, orientado a identificar activos críticos, amenazas y vulnerabilidades, y a traducirlos en riesgos gestionables. Se estructura en tres fases (perfilado de activos y amenazas, análisis de infraestructura y desarrollo de estrategia de seguridad) y cuatro procesos en la fase 1, entre los que destaca "Identify Enterprise Knowledge" donde ya se recogen "indicadores de riesgo" percibidos por la alta dirección.

Aunque OCTAVE no define un catálogo rígido de KPIs, sí introduce el concepto de "risk indicators" ligados a:

- Valor del activo (importancia para la misión).
- Gravedad del impacto en distintas dimensiones (reputación, financiero, cumplimiento, salud, seguridad, productividad, etc.).
- Exposición a amenazas y vulnerabilidades identificadas.[^3][^16]

Estos indicadores se operacionalizan de forma cualitativa (bajo, medio, alto) mediante criterios definidos por la organización, que sirven de base para priorizar riesgos y diseñar la estrategia de control.[^1][^16]

1.2. OCTAVE Allegro: criterios de impacto y perfiles de activos

OCTAVE Allegro, publicado por SEI como "next generation" del método, simplifica y agiliza la evaluación poniendo el foco en activos de información concretos y sus contenedores (personas, papel, sistemas, redes). El corazón de Allegro es la definición de criterios de medición del riesgo (risk measurement criteria) antes de analizar amenazas:[^4][^1]

- Categorías de impacto típicas: reputación, confianza del cliente, productividad, financiero, sanciones legales, seguridad física, salud.[^18][^1]
- Escalas de impacto (por ejemplo, pérdida de ingresos, duración de la interrupción, tamaño del colectivo afectado) con umbrales numéricos o descriptivos para bajo, medio y alto.[^19][^18]

Una vez definidos los criterios, Allegro sigue ocho pasos: establecer criterios, perfilar el activo, identificar contenedores, áreas de preocupación, escenarios de amenaza, riesgos, análisis de riesgos y selección de mitigación. En la práctica, esto se traduce en indicadores como:[^4][^1]

- Número de activos de información críticos identificados y perfilados.
- Porcentaje de activos con criterios de impacto formalizados.
- Número de escenarios de amenaza por activo y nivel de riesgo agregado.
- Distribución de riesgos por niveles (bajo/medio/alto) y por categoría de impacto.

Estudios recientes aplicando Allegro a infraestructuras críticas como Advanced Metering Infrastructure (AMI) o sistemas de gestión de flotas siguen esta lógica, identificando entre 6 y 10 activos críticos y priorizando entre 4 y 11 riesgos de alto impacto, con recomendaciones de mitigación ligadas a esos indicadores.[^20][^21][^22]

1.3. OCTAVE FORTE: puente entre ERM y ciberseguridad

OCTAVE FORTE es el modelo más reciente de la familia, pensado explícitamente como proceso de Enterprise Risk Management que conecta a ejecutivos, mandos intermedios y técnicos. Su marco de 10 pasos guía a la organización para:[^23][^24][^2]

- Entender activos, capacidades y riesgos.
- Formular declaraciones de apetito de riesgo.
- Crear planes de respuesta.
- Establecer procesos para monitorizar si el riesgo se gestiona de forma efectiva.[^24][^2]

El énfasis ya no está solo en la fotografía del riesgo, sino en la construcción de un programa de riesgo repetible, medible y coherente con la estrategia corporativa. FORTE se alinea de forma natural con indicadores de gobierno (existencia de comité de riesgos, políticas aprobadas, seguimiento periódico, integración en planificación estratégica) y con métricas de madurez del propio programa (consistencia, repetibilidad, cobertura organizativa).^{[2][25][24]}

1.4. OCTAVE en 2025-2026: lugar en el ecosistema de marcos

En el ecosistema actual de marcos de gestión de riesgo cibernético —NIST CSF, ISO/IEC 27005, FAIR, etc. — OCTAVE sigue ocupando un espacio particular: metodología auto-dirigida, muy orientada al contexto de negocio y con alta flexibilidad.

- Guías recientes describen OCTAVE como marco ligero, adaptable y centrado en riesgos operacionales ligados a activos críticos, complementario a marcos más normativos como NIST CSF.^{[26][27]}
- Artículos académicos de 2022-2025 lo combinan con FMEA, ISO 27001:2022 o métodos cuantitativos para priorizar riesgos mediante números de prioridad de riesgo (RPN) u otras métricas numéricas.^{[28][29]}

En suma, OCTAVE ha ido desplazándose desde una lista esencialmente cualitativa de impactos hacia esquemas híbridos donde los criterios de impacto se cuantifican y se utilizan para generar indicadores y rankings de riesgo comparables entre proyectos, unidades... o países.

2. Tendencias recientes en medición de ciberseguridad (2024-2026)

2.1. De contar controles a medir resultados y madurez

En la conversación global, la medición de la ciberseguridad ha evolucionado desde contar controles implementados hasta medir resultados (incidentes, pérdidas, resiliencia) y madurez organizativa.

- La OCDE, en su informe "New perspectives on measuring cybersecurity" de 2024, plantea un marco de inputs (políticas, recursos), outputs (comportamientos) y outcomes (menos incidentes, menos daño, más confianza) como guía para diseñar indicadores comparables entre países.^{[30][13]}
- ENISA, con su metodología NIS360 (2023-2024), evalúa la madurez y criticidad de sectores cubiertos por NIS2 mediante indicadores estructurados por dimensiones, para situarlos en un cuadrante criticidad-madurez y destacar aquellos en "zona de riesgo".^[6]
- El EU-Cybersecurity Index 2024 de ENISA organiza 84 indicadores cualitativos y cuantitativos en cuatro áreas (política, operaciones, capacidades y mercado/industria) y 16 subáreas, ponderados para ofrecer una puntuación agregada por país.^{[9][14]}

Estos enfoques encajan bien con OCTAVE FORTE, que insiste en que el programa de gestión de riesgos debe ser medible, consistente y repetible, y con OCTAVE Allegro, que exige criterios de impacto claros antes de valorar riesgos.^{[2][1]}

2.2. Índices internacionales: GCI, NCSI y EU-Cybersecurity Index

A nivel internacional, varios índices proporcionan un cuadro de mando de la capacidad cibernética nacional:

- El Global Cybersecurity Index (GCI) de la UIT evalúa a los países en cinco dimensiones (marco legal, técnico, organizativo, fomento de capacidades y cooperación), utilizando indicadores sobre legislación, CSIRTs nacionales, formación, mecanismos de cooperación y más.^[15]
- El National Cyber Security Index (NCSI), mantenido por la e-Governance Academy, puntúa a los países en indicadores estratégicos como política de ciberseguridad, respuesta a incidentes, protección de servicios esenciales, educación y formación, basándose en evidencias documentales (leyes, estrategias, sitios oficiales).^[8]
- El EU-Cybersecurity Index 2024, ya citado, combina indicadores sobre políticas, operaciones, capacidades y mercado, muchos de ellos compatibles con métricas derivadas de marcos como OCTAVE FORTE (gobernanza y gestión del riesgo) o Allegro (gestión de activos y vulnerabilidades).^{[14][9]}

Aunque estos índices no utilizan explícitamente OCTAVE, sus indicadores pueden reinterpretarse como "criterios de impacto" a escala nacional (por ejemplo, impacto en resiliencia, continuidad de servicios esenciales, confianza del público) y como "indicadores de riesgo" agregados (puntuación global, debilidades en sectores específicos).

2.3. Medir la incertidumbre y el riesgo emergente

El informe de la OCDE subraya la dificultad de medir el riesgo cibernético debido a la escasez de datos, incentivos limitados para compartir información y sesgos en las fuentes disponibles. Propone, entre otras cosas:^[13]

- Desarrollar indicadores de "incertidumbre cibernética" (dispersión, volatilidad, falta de información) para complementar las métricas tradicionales.
- Utilizar pruebas de concepto que combinen datos de incidentes, encuestas empresariales y fuentes alternativas (por ejemplo, escaneos de exposición) para anticipar tendencias.^[13]

Esta línea puede integrarse en OCTAVE como una capa adicional de indicadores: no solo medir el riesgo estimado, sino también cuánta incertidumbre existe alrededor de esa estimación, lo que resulta especialmente relevante a nivel nacional cuando se agregan datos de múltiples sectores con niveles de reporte muy heterogéneos.

3. España: estrategias, marcos y datos de ciberseguridad

3.1. Estrategia Nacional de Ciberseguridad y Plan Nacional de Ciberseguridad

La Estrategia Nacional de Ciberseguridad 2019, publicada por Orden PCI/487/2019, establece objetivos para reforzar capacidades ante amenazas, garantizar la seguridad y resiliencia de activos estratégicos, impulsar la ciberseguridad de ciudadanos y empresas, y fortalecer la coordinación institucional mediante el Consejo Nacional de Ciberseguridad. Sobre esta base, el Plan Nacional de Ciberseguridad aprobado en 2022 prevé cerca de 150 iniciativas y, entre ellas, el desarrollo de un "sistema integrado de indicadores de ciberseguridad a nivel nacional" y un sistema de seguimiento y control con informe anual.^{[11][31][32][33]}

Este énfasis en un sistema integrado de indicadores abre la puerta a utilizar OCTAVE como marco conceptual para:

- Definir categorías de impacto a nivel país (servicios esenciales, economía, reputación internacional, derechos fundamentales, etc.).
- Mapear amenazas y vulnerabilidades sobre activos estratégicos nacionales (infraestructuras críticas, administración electrónica, tejido empresarial, ciudadanía).^{[32][11]}

3.2. Esquema Nacional de Seguridad (ENS) y cultura de indicadores

El Real Decreto 311/2022 aprueba el nuevo ENS, que establece principios básicos y requisitos mínimos de seguridad para los sistemas de información de las administraciones públicas y sus proveedores. El ENS subraya:^{[12][34]}

- La gestión de la seguridad basada en riesgos (artículo 7).
- La vigilancia continua y la reevaluación periódica (artículo 10).
- La auditoría de la seguridad y el informe del estado de la seguridad (artículos 31 y 32).^[12]

Implementaciones concretas del ENS, como la de la Universidad de Zaragoza, evidencian la existencia de informes anuales (INES) que reflejan el estado de cumplimiento de indicadores propuestos por el Centro Criptológico Nacional (CCN). En la práctica, se trabaja con indicadores tipo:^[35]

- Grado de cumplimiento de medidas del ENS por sistema.
- Número de auditorías realizadas y hallazgos por categoría.
- Evolución del estado de madurez de seguridad de los sistemas.

Todo ello es muy compatible con la filosofía OCTAVE: análisis basado en riesgos, priorización de activos, definición de medidas, seguimiento mediante indicadores.

3.3. INCIBE y métricas operacionales de incidentes

El Instituto Nacional de Ciberseguridad (INCIBE) publica anualmente balances de ciberseguridad que incluyen cifras agregadas de incidentes gestionados, sistemas vulnerables detectados y distribución sectorial.^{[7][36][10]}

- En 2024, INCIBE gestionó 97.348 incidentes, un aumento del 16,6% respecto a 2023; el 67,6% afectó a ciudadanos y el 32,4% a empresas, con más de 183.000 sistemas vulnerables detectados.^{[36][7]}
- En 2025, los incidentes se elevaron a 122.223 (26% más que en 2024), con 237.028 sistemas vulnerables relevantes y 401 incidentes en operadores esenciales sujetos a NIS2, con banca, transporte y energía como sectores más afectados.^[10]

Estos datos ya dan lugar a indicadores OCTAVE-compatibles a nivel nacional, tales como:

- Frecuencia de incidentes por sector y tipo de actor (ciudadanía, empresas, operadores esenciales).
- Densidad de sistemas vulnerables (por millón de habitantes, por empresa, por sistema de información crítico).
- Tendencia interanual de incidentes y vulnerabilidades.

3.4. Posición de España en índices internacionales

España figura en índices internacionales como el NCSI de la e-Governance Academy, el EU-Cybersecurity Index de ENISA y el GCI de la UIT. Por ejemplo:[⁸][¹⁵][¹⁴]

- El NCSI asigna puntuaciones a indicadores estratégicos como la existencia de liderazgo político de alto nivel en ciberseguridad, estrategias nacionales, CSIRTs, mecanismos de notificación de incidentes y otros.[⁸]
- El EU-Cybersecurity Index recoge indicadores sobre políticas, operaciones (p. ej., monitorización de amenazas, respuesta a incidentes), capacidades (formación, concienciación) y mercado/industria que permiten comparar la madurez relativa de España frente a otros Estados miembros.[⁹][¹⁴]

Estos índices pueden considerarse, de facto, como "OCTAVE nacional" de alto nivel: definen activos (capacidad institucional, marco normativo), amenazas (panorama de incidentes, sectores críticos) y vulnerabilidades (lagunas de capacidad) y los agregan en puntuaciones comparables.

4. De OCTAVE organizacional a OCTAVE nacional para España

4.1. Reinterpretar los elementos de OCTAVE a escala país

Para adaptar OCTAVE al nivel nacional (territorial) en España, es útil hacer una analogía directa con sus elementos básicos:

- Activos – activos estratégicos nacionales: servicios esenciales (energía, agua, transporte, salud, banca), sistemas de administración pública digital, infraestructura de comunicaciones, datos de carácter personal, propiedad intelectual clave, confianza de la ciudadanía en el entorno digital.[³⁷][³²]
- Amenazas – amenazas cibernéticas relevantes: ransomware, ataques a disponibilidad, intrusiones, fraude en línea, campañas de desinformación, explotación de vulnerabilidades masivas.[³⁸][⁷]
- Vulnerabilidades – debilidades estructurales: sistemas sin parchear, déficit de competencias, marcos normativos incompletos, baja cultura de ciberseguridad en pymes, ausencia de coordinación entre organismos.[⁶][¹³]

Los criterios de impacto de Allegro se pueden traducir a dimensiones nacionales tales como:

- Impacto en continuidad de servicios esenciales.
- Impacto económico agregado (PIB, sectores clave).
- Impacto en derechos fundamentales y confianza ciudadana.
- Impacto reputacional internacional y en alianzas.[¹¹][³²][¹]

4.2. Sinergias con NIS2, NIS360, ENS y el sistema integrado de indicadores

La Directiva NIS2 amplía significativamente el elenco de sectores y entidades esenciales y establece obligaciones de gestión de riesgos y notificación que requieren indicadores sólidos. ENISA, a través de NIS360, propone precisamente un esquema de indicadores de criticidad y madurez por sector que puede verse como una visión sectorial derivada de OCTAVE FORTE: activos (sectores críticos), amenazas

(escenario de amenaza europeo), vulnerabilidades (baja madurez), riesgos (sectores en zona de riesgo).
[³⁹][⁶]

A nivel interno, el ENS y el sistema integrado de indicadores anunciado en el Plan Nacional de Ciberseguridad apuntan a consolidar un cuadro de mando nacional que integre:

- Indicadores de cumplimiento y madurez ENS en administraciones.
- Indicadores de incidentes y vulnerabilidades (INCIBE-CERT, CCN-CERT).
- Indicadores de capacidad y recursos (formación, inversión, ciberseguridad en pymes). [³⁵][¹¹][¹²]

Injectar la lógica de OCTAVE en este sistema significaría que los indicadores no solo midan "cuántos controles" se cumplen, sino también cómo se distribuyen los riesgos y qué criterios de impacto se están utilizando para priorizarlos.

4.3. Comparación internacional: adaptar índices al lenguaje OCTAVE

Los índices internacionales aportan comparabilidad, pero a menudo se perciben como cajas negras. Una lectura OCTAVE-friendly podría consistir en:

- Interpretar cada indicador del EU-Cybersecurity Index como criterio de impacto o capacidad en una dimensión concreta (política, operaciones, capacidades, mercado/industria). [¹⁴][⁹]
- Relacionar la puntuación de España en GCI y NCSI con su "apetito de riesgo" y su posición relativa en la gestión de riesgos a escala nacional. [¹⁵][⁸]
- Conectar estos índices con métricas operacionales (INCIBE, ENS) y con los criterios de impacto que se utilicen en el sistema integrado de indicadores.

De este modo, el "OCTAVE nacional" para España no sería un marco nuevo, sino una capa de interpretación y priorización sobre los marcos existentes.

5. Propuesta de taxonomía de indicadores OCTAVE para España

5.1. Ejes principales

Tomando como base OCTAVE Allegro/FORTE y los marcos ENS, NIS2, NIS360 y EU-Cybersecurity Index, se propone estructurar los indicadores nacionales en cinco ejes OCTAVE-compatibles:

1. Activos nacionales críticos (qué protegemos).
2. Amenazas y eventos (qué ocurre).
3. Vulnerabilidades y exposición (dónde somos frágiles).
4. Capacidades y respuesta (cómo reaccionamos y nos preparamos).
5. Resultados y resiliencia (qué efecto tienen las medidas). [²⁴][¹][⁹][¹³][⁶]

5.2. Tabla de indicadores propuestos

La siguiente tabla ofrece ejemplos de indicadores alineados con estos ejes, con una lectura orientada a OCTAVE y pensados para el contexto español:

Eje OCTAVE	Indicador propuesto	Descripción resumida
Activos	Inventario de servicios esenciales digitalizados	% de servicios esenciales que dependen críticamente de TIC para operar (por sector: energía, agua, salud, transporte, banca).
Activos	Cobertura ENS en administraciones	% de organismos de la AGE y AA.PP. autonómicas y locales con sistemas categorizados y sometidos a ENS.
Activos	Protección de datos personales	% de bases de datos de alto valor (salud, hacienda, justicia) cubiertas por planes de seguridad y continuidad auditados.
Amenazas	Incidentes por sector	Número de incidentes gestionados por INCIBE-CERT y CCN-CERT por sector y tipo de amenaza (ransomware, fraude, intrusiones, disponibilidad).
Amenazas	Tendencia de incidentes nacionales	Variación interanual de incidentes totales (p. ej., +26% en 2025 respecto a 2024) y distribución ciudadanía/empresas/operadores esenciales.[^7][^10]
Amenazas	Amenazas contra disponibilidad	Proporción de incidentes clasificados como ataques a la disponibilidad, en línea con las tendencias de ENISA Threat Landscape.[^38]
Vulnerabilidades	Sistemas vulnerables detectados	Número y densidad de sistemas vulnerables relevantes detectados proactivamente (por población, por empresa, por organismo).[^7][^10]
Vulnerabilidades	Exposición de servicios esenciales	% de sistemas de operadores esenciales con vulnerabilidades críticas sin parchear en plazos definidos.
Vulnerabilidades	Brechas de capacidad	Indicadores de falta de personal cualificado, gaps en cumplimiento ENS, sectores en "zona de riesgo" según NIS360. [^6][^9]

Capacidades	Gobernanza y liderazgo	Existencia de liderazgo político alto nivel, Consejo Nacional de Ciberseguridad, estrategias y planes actualizados.[¹¹][³¹][⁸]
Capacidades	Capacidad de respuesta nacional	Madurez de los CSIRTs nacionales, tiempo medio de respuesta, cobertura sectorial (según GCI, NCSI, EU-Cybersecurity Index).[¹⁴][⁸][¹⁵]
Capacidades	Cultura y formación	Porcentaje de empresas que realizan evaluación de riesgos de ciberseguridad y formación periódica, según estadísticas europeas y nacionales.[¹⁴][¹³]
Resultados	Pérdidas económicas estimadas	Estimaciones de pérdidas económicas por ciberincidentes en sectores clave (cuando existan) y tendencia.
Resultados	Continuidad de servicios esenciales	Número de interrupciones significativas de servicios esenciales debidas a ciberincidentes y duración media.
Resultados	Confianza digital	Indicadores de confianza de ciudadanos y empresas en servicios digitales (encuestas nacionales y europeas).

Esta taxonomía permite construir un "perfil de riesgo nacional" al estilo OCTAVE, agregando indicadores por eje y priorizando aquellos que muestran mayor brecha entre criticidad y madurez.

6. Ejemplos de preguntas de encuesta y opciones de respuesta

La adaptación de OCTAVE a escala nacional requiere, inevitablemente, formular preguntas incómodas a actores estratégicos. A continuación se proponen bloques de preguntas y escalas de respuesta orientadas a operadores esenciales, administraciones y grandes organizaciones españolas, con un tono deliberadamente claro y ligeramente irónico.

6.1. Bloque 1: identificación de activos nacionales críticos

Pregunta 1.1. En su organización, ¿los activos de información críticos están identificados y documentados de forma sistemática, incluyendo sus dependencias con servicios esenciales?

- Nada en absoluto: "nuestros activos críticos se identifican por el ruido que hacen cuando fallan".
- Parcialmente: "tenemos listas dispersas y heroicas hojas de cálculo".
- Sustancialmente: "disponemos de un inventario formal, aunque las dependencias no siempre están actualizadas".
- Completamente: "inventario central, modelo de dependencias y revisión regular; dormir, lo que se dice dormir, dormimos bastante tranquilos".

Pregunta 1.2. ¿Con qué frecuencia se revisa y actualiza el inventario de activos críticos?

- Solo después de un incidente grave.
- De forma ad-hoc, cuando alguien se acuerda.
- Al menos una vez al año.
- De forma continua, integrada en los procesos de cambio y gestión de activos.

6.2. Bloque 2: criterios de impacto y apetito de riesgo

Pregunta 2.1. ¿Dispone su organización de criterios formales para valorar el impacto de un incidente en dimensiones como continuidad del servicio, impacto económico, reputación, cumplimiento normativo y seguridad de las personas?

- No, seguimos el método universal: "baja, media, alta" a ojo.
- Sí, pero solo para algunos proyectos o sistemas.
- Sí, tenemos criterios definidos y documentados, aunque su aplicación es desigual.
- Sí, criterios formales alineados con ENS, NIS2 y la estrategia corporativa, aplicados de forma consistente.

Pregunta 2.2. ¿Existe una declaración explícita de apetito de riesgo en ciberseguridad aprobada por el órgano de gobierno de su organización?

- No, el apetito de riesgo se mide por el número de noches en vela del CISO.
- Se comenta en reuniones, pero no está formalmente aprobado.
- Sí, existe un documento aprobado pero poco conocido.
- Sí, existe, se revisa periódicamente y se usa para priorizar inversiones y decisiones clave.

6.3. Bloque 3: amenazas, incidentes y notificación

Pregunta 3.1. ¿Con qué grado de sistematicidad registra y clasifica su organización los incidentes de ciberseguridad (incluyendo intentos fallidos relevantes)?

- Apenas registramos nada; cada incidente es una anécdota épica.
- Registramos incidentes graves, pero sin taxonomía homogénea.
- Registramos y clasificamos incidentes con una taxonomía básica (por tipo de amenaza, impacto y servicio afectado).
- Registramos, clasificamos y analizamos tendencias, integrando la información con los CSIRTs competentes.

Pregunta 3.2. En caso de incidentes que afecten a servicios esenciales o datos sensibles, ¿se cumplen los plazos y requisitos de notificación establecidos por NIS2, ENS y normativa aplicable?

- Lo sabremos cuando llegue la primera sanción.
- Se intenta, pero los procesos no están plenamente definidos.
- Generalmente sí, aunque hay margen de mejora en coordinación y tiempos de respuesta.
- Sí, existen procedimientos claros, automatismos y simulacros periódicos.

6.4. Bloque 4: vulnerabilidades y exposición

Pregunta 4.1. ¿Qué nivel de control tiene su organización sobre las vulnerabilidades técnicas de sus sistemas críticos (inventario, priorización, parcheo)?

- Bajo: la frase "sistema en explotación" es sinónimo de "arqueología digital".
- Medio: se gestionan vulnerabilidades críticas, pero de forma reactiva.
- Alto: existe un proceso de gestión de vulnerabilidades con priorización basada en riesgo.
- Muy alto: procesos automatizados, métricas de tiempo de parcheo, y revisiones coordinadas con proveedores y terceros.

Pregunta 4.2. ¿Se monitoriza la exposición externa de activos críticos (por ejemplo, mediante escaneos periódicos, programas de bug bounty o servicios de threat intelligence)?

- No, preferimos la emoción de las sorpresas.
- Sí, pero de forma puntual o ligada a proyectos concretos.
- Sí, con escaneos y monitores periódicos para activos clave.
- Sí, con un programa estructurado de gestión de superficie de ataque, incluidos terceros.

6.5. Bloque 5: capacidades, respuesta y resiliencia

Pregunta 5.1. ¿Cuál es el nivel de preparación de su organización para responder a incidentes de ciberseguridad que afecten a la continuidad del negocio?

- Básico: sabemos a quién llamar, pero el plan está más en las cabezas que en el papel.
- Intermedio: existen planes de respuesta y continuidad, pero se prueban poco.
- Avanzado: existen planes documentados, roles claros y simulacros anuales.
- Excelente: planes integrados negocio-TI, simulacros frecuentes, lecciones aprendidas, métricas de tiempo de recuperación.

Pregunta 5.2. ¿Cómo describiría la cultura de ciberseguridad en su organización?

- "Eso es cosa de informática".
- "Sabemos que es importante, pero manda la urgencia del día a día".
- "La ciberseguridad forma parte visible de la gestión de riesgos".
- "Es un deporte de equipo: negocio, tecnología y proveedores reman en la misma dirección".

6.6. Bloque 6: alineamiento con marcos nacionales e internacionales

Pregunta 6.1. ¿En qué medida está alineado su sistema de gestión de riesgos de ciberseguridad con el ENS, NIS2 y los marcos nacionales (Estrategia Nacional, Plan Nacional de Ciberseguridad)?

- Aún estamos descifrando el acrónimo ENS.
- Se han realizado análisis de brecha, pero la implementación es incipiente.
- Existe una hoja de ruta clara de alineamiento en ejecución.
- La alineación es alta y se revisa periódicamente con auditorías internas y externas.

Pregunta 6.2. ¿Utiliza su organización benchmarks internacionales (GCI, NCSI, EU-Cybersecurity Index) para evaluar su posición relativa y orientar inversiones?

- No, nuestra métrica es "si nadie se ha quejado, vamos bien".
- Sí, de manera informal, en presentaciones puntuales.
- Sí, como referencia estratégica en la definición de objetivos.
- Sí, con objetivos cuantificados de convergencia hacia mejores prácticas.

Estas baterías de preguntas pueden combinarse con escalas Likert clásicas (1-5) y con preguntas abiertas para capturar matices, manteniendo la estructura conceptual OCTAVE (activos-amenazas-vulnerabilidades-riesgos-controles) y el alineamiento con los marcos españoles y europeos vigentes.

7. Conclusiones y líneas de acción propositivas

6. OCTAVE sigue siendo pertinente, pero necesita apellidos. Allegro y FORTE aportan la granularidad de criterios de impacto y la capa de ERM que permiten hablar de indicadores robustos y comparables a nivel nacional.[¹][²⁴][²]
7. España tiene los ladrillos pero aún puede mejorar la arquitectura. Estrategia Nacional de Ciberseguridad, Plan Nacional, ENS, INCIBE y la integración con NIS2 ofrecen datos y marcos que, leídos en clave OCTAVE, permiten construir un sistema integrado de indicadores alineado con las mejores prácticas europeas.[⁷][¹⁰][¹¹][¹²]
8. Los índices internacionales no son enemigos, sino espejos. GCI, NCSI y el EU-Cybersecurity Index proporcionan indicadores agregados que pueden servir como criterios de impacto y madurez para un "OCTAVE nacional" capaz de situar a España en contexto y priorizar inversiones.[⁹][¹⁵][¹⁴][⁸]
9. Medir la incertidumbre es tan importante como medir el riesgo. La agenda de la OCDE sobre incertidumbre cibernética invita a incorporar indicadores de calidad de datos, cobertura y sesgos, algo especialmente relevante cuando se agregan métricas de múltiples sectores y fuentes.[¹³]
10. La encuesta importa tanto como el marco. Las preguntas y escalas de respuesta propuestas no son un mero trámite burocrático: son instrumentos para alinear lenguaje, expectativas y prioridades entre CISOs, reguladores y decisores políticos, evitando a la vez el tono apocalíptico y el exceso de complacencia.

En definitiva, un enfoque OCTAVE aplicado a nivel nacional para España, alimentado por fuentes oficiales e internacionales y enriquecido con una cultura de medición honesta y autocrítica, puede convertirse en una brújula útil para navegar el creciente mar de riesgos cibernéticos. Eso sí, como todo buen instrumento de medición, solo es tan útil como la voluntad de mirar de frente lo que revela.

References

11.
Security Risk Assessment Using OCTAVE Allegro
12.
Advancing Risk Management Capability Using the OCTAVE FORTE ... - OCTAVE FORTE is a process model that helps organizations evaluate their security risks and use ERM p...
13.
Operationally Critical Threat, Asset, and Vulnerability ... - The Operationally Critical Threat, Asset, and Vulnerability Evaluation (OCTAVE) is a framework for i...
14.
Introducing OCTAVE Allegro: Improving the Information Security ... - OCTAVE Allegro is a methodology to streamline and optimize the process of assessing information secu...
15.
OCTAVE (Operationally Critical Threat, Asset and Vulnerability Evaluation)
16.
[PDF] enisa nis360 2024 - The European Union Agency for Cybersecurity, ENISA, is the Union's agency dedicated to achieving a h...
17.
INCIBE presenta su balance de ciberseguridad 2024 con más de ... - INCIBE ha hecho público su balance de ciberseguridad de 2024 con un incremento del 16,6% respecto a ...
18.
NCSI :: Spain - National Cyber Security Index - STRATEGIC CYBERSECURITY INDICATORS. 1. CYBERSECURITY POLICY 12/15 80%. 12. 15 ... INCIBE report 2024...
19.
[PDF] eu cybersecurity index - Digital Russia - The European Union Agency for Cybersecurity, ENISA, is the Union's agency dedicated to achieving a h...
20.
INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un ... - 122.223 incidentes de ciberseguridad, lo que supone un aumento del 26% respecto a 2024. · 237.028 si...

21.
El Gobierno aprueba el Plan Nacional de Ciberseguridad - martes, 29 de marzo de 2022. El Consejo de Ministros ha aprobado el Plan Nacional de Ciberseguridad,...
22.
BOE-A-2022-7191 Real Decreto 311/2022, de 3 de mayo, por el ... - Principios básicos del Esquema Nacional de Seguridad. Artículo 6. La seguridad como un proceso integ...
23.
New perspectives on measuring cybersecurity - Measuring the various aspects of cybersecurity across countries is challenging, in part because the ...
24.
THE EU-Cybersecurity Index 2024 - ENISA - European Union www.enisa.europa.eu › files › The EU Cybersecurity Index 2024_en_0
25.
Global Cybersecurity Index 2024 - ITU - The GCI sits at the nexus of cybersecurity metrics, by assessing the measures taken by countries at ...
26.
[PDF] Operationally Critical Threat, Asset, and Vulnerability Evaluation - OCTAVE defines a set of self-directed activities for organizations to identify and manage their info...
27.
Cybersecurity Threat Modeling with OCTAVE - Pluralsight - This guide provides a high-level overview of how to use OCTAVE, a flexible methodology for helping o...
28.
Lean Risk Assessment based on OCTAVE Allegro - OCTAVE Allegro is an asset centric and lean risk assessment successor of the OCTAVE method. The meth...
29.
[PDF] OCTAVE Allegro Risk Assessment: The George Washington ... - The most significant risk measurement criteria for GWU Hospital are Reputation, Financial, Productiv...
30.
[PDF] Risk assessment in fleet management system using OCTAVE allegro - The purpose of this study is to use the OCTAVE allegro methodology to identify risks in fleet manage...

31.
Assessment of potential security risks in advanced metering ... - This study contributes to AMI security by assessing the potential security risks using the OCTAVE Al...
32.
[PDF] Risk assessment for the cyber threats to networked critical ...
33.
SEI Releases OCTAVE FORTE Model for Enterprise Risk ... - The OCTAVE FORTE process model helps organizations evaluate their security risks and use enterprise ...
34.
10 Steps for Managing Risk: OCTAVE FORTE - The SEI developed OCTAVE FORTE, a process model that helps organizations evaluate their security ris...
35.
OCTAVE FORTE and FAIR Connect Cyber Risk Practitioners with ... - This connection helps organizations understand and prioritize complex risks while balancing other co...
36.
OCTAVE® (Operationally Critical Threat, Asset, and Vulnerability ... - OCTAVE® is an acronym for "Operationally Critical Threat, Asset, and Vulnerability Evaluation," a co...
37.
Top 5 cybersecurity frameworks for reducing cyber risk - Explore cybersecurity framework list to find the top 5 frameworks that help reduce cyber risks, ensu...
38.
Analisis dan Manajemen Risiko Keamanan Aset Teknologi Informasi Menggunakan Metode OCTAVE dan FMEA Berbasis ISO 27001:2022: Studi Kasus : Perusahaan XYZ - The advancement of information technology has driven companies to adopt technology-based systems to ...
39.
[PDF] Risk analysis and mitigation strategies in overcoming cyber attacks ... - In this study, the OCTAVE risk assessment method is used because it is able to focus on assessing th...
40.
REady or not? New Perspectives on Measuring and Monitoring cybersecurity

41.
BOE-A-2019-6347 Orden PCI/487/2019, de 26 de abril, por ... - BOE-A-2019-6347 Orden PCI/487/2019, de 26 de abril, por la que se publica la Estrategia Nacional de ...
42.
PRESIDENCIA
43.
Estrategia Nacional de Ciberseguridad 2019
44.
Cómo implementar el ENS paso a paso en una organización - ESED - Implementar el Esquema Nacional de Seguridad (ENS) en una organización es un proceso riguroso que ex...
45.
Esquema Nacional de Seguridad | Universidad de Zaragoza - El Esquema Nacional de Seguridad es una regulación de carácter estatal, que tiene por objeto estable...
46.
INCIBE presenta su balance de ciberseguridad 2024 con más de ... - INCIBE presenta su balance de ciberseguridad 2024 con más de 97.000 incidentes gestionados · Malware...
47.
Not If, But When: Critical Infrastructure Protection and Resilience - Essential services like power, fuel, transportation, healthcare, communications and more are referre...
48.
ENISA Threat Landscape 2024 - European Union - Seven prime cybersecurity threats were identified in 2024, with threats against availability topping...
49.
The ENISA NIS Investments 2024 Report: A Cybersecurity ... - The ENISA NIS Investments 2024 report highlights a key trend: cybersecurity investments in the EU ar...

Security Risk Assessment Using OCTAVE Allegro

Advancing Risk Management Capability Using the OCTAVE FORTE ... - OCTAVE FORTE is a process model that helps organizations evaluate their security risks and use ERM p...

Operationally Critical Threat, Asset, and Vulnerability ... - The Operationally Critical Threat, Asset, and Vulnerability Evaluation (OCTAVE) is a framework for i...

Introducing OCTAVE Allegro: Improving the Information Security ... - OCTAVE Allegro is a methodology to streamline and optimize the process of assessing information secu...

OCTAVE (Operationally Critical Threat, Asset and Vulnerability Evaluation)

[PDF] enisa nis360 2024 - The European Union Agency for Cybersecurity, ENISA, is the Union's agency dedicated to achieving a h...

INCIBE presenta su balance de ciberseguridad 2024 con más de ... - INCIBE ha hecho público su balance de ciberseguridad de 2024 con un incremento del 16,6% respecto a ...

NCSI :: Spain - National Cyber Security Index - STRATEGIC CYBERSECURITY INDICATORS. 1. CYBERSECURITY POLICY 12/15 80%. 12. 15 ... INCIBE report 2024...

[PDF] eu cybersecurity index - Digital Russia - The European Union Agency for Cybersecurity, ENISA, is the Union's agency dedicated to achieving a h...

INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un ... - 122.223 incidentes de ciberseguridad, lo que supone un aumento del 26% respecto a 2024. · 237.028 si...

El Gobierno aprueba el Plan Nacional de Ciberseguridad - martes, 29 de marzo de 2022. El Consejo de Ministros ha aprobado el Plan Nacional de Ciberseguridad,...

BOE-A-2022-7191 Real Decreto 311/2022, de 3 de mayo, por el ... - Principios básicos del Esquema Nacional de Seguridad. Artículo 6. La seguridad como un proceso integ...

New perspectives on measuring cybersecurity - Measuring the various aspects of cybersecurity across countries is challenging, in part because the ...

THE EU-Cybersecurity Index 2024 - ENISA - European Union www.enisa.europa.eu › files › The EU Cibersecurity Index 2024_en_0

Global Cybersecurity Index 2024 - ITU - The GCI sits at the nexus of cybersecurity metrics, by assessing the measures taken by countries at ...

[PDF] Operationally Critical Threat, Asset, and Vulnerability Evaluation - OCTAVE defines a set of self-directed activities for organizations to identify and manage their info...

Cybersecurity Threat Modeling with OCTAVE - Pluralsight - This guide provides a high-level overview of how to use OCTAVE, a flexible methodology for helping o...

Lean Risk Assessment based on OCTAVE Allegro - OCTAVE Allegro is an asset centric and lean risk assessment successor of the OCTAVE method. The meth...

[PDF] OCTAVE Allegro Risk Assessment: The George Washington ... - The most significant risk measurement criteria for GWU Hospital are Reputation, Financial, Productiv...

[PDF] Risk assessment in fleet management system using OCTAVE allegro - The purpose of this study is to use the OCTAVE allegro methodology to identify risks in fleet manage...

Assessment of potential security risks in advanced metering ... - This study contributes to AMI security by assessing the potential security risks using the OCTAVE AI...

[PDF] Risk assessment for the cyber threats to networked critical ...

SEI Releases OCTAVE FORTE Model for Enterprise Risk ... - The OCTAVE FORTE process model helps organizations evaluate their security risks and use enterprise ...

10 Steps for Managing Risk: OCTAVE FORTE - The SEI developed OCTAVE FORTE, a process model that helps organizations evaluate their security ris...

OCTAVE FORTE and FAIR Connect Cyber Risk Practitioners with ... - This connection helps organizations understand and prioritize complex risks while balancing other co...

OCTAVE® (Operationally Critical Threat, Asset, and Vulnerability ... - OCTAVE® is an acronym for "Operationally Critical Threat, Asset, and Vulnerability Evaluation," a co...

Top 5 cybersecurity frameworks for reducing cyber risk - Explore cybersecurity framework list to find the top 5 frameworks that help reduce cyber risks, ensu...

Analisis dan Manajemen Risiko Keamanan Aset Teknologi Informasi Menggunakan Metode OCTAVE dan FMEA Berbasis ISO 27001:2022: Studi Kasus : Perusahaan XYZ - The advancement of information technology has driven companies to adopt technology-based systems to ...

[PDF] Risk analysis and mitigation strategies in overcoming cyber attacks ... - In this study, the OCTAVE risk assessment method is used because it is able to focus on assessing th...

REady or not? New Perspectives on Measuring and Monitoring cybersecurity

BOE-A-2019-6347 Orden PCI/487/2019, de 26 de abril, por ... - BOE-A-2019-6347 Orden PCI/487/2019, de 26 de abril, por la que se publica la Estrategia Nacional de ...

PRESIDENCIA

Estrategia Nacional de Ciberseguridad 2019

Cómo implementar el ENS paso a paso en una organización - ESED - Implementar el Esquema Nacional de Seguridad (ENS) en una organización es un proceso riguroso que ex...

Esquema Nacional de Seguridad | Universidad de Zaragoza - El Esquema Nacional de Seguridad es una regulación de carácter estatal, que tiene por objeto estable...

INCIBE presenta su balance de ciberseguridad 2024 con más de ... - INCIBE presenta su balance de ciberseguridad 2024 con más de 97.000 incidentes gestionados · Malware...

Not If, But When: Critical Infrastructure Protection and Resilience - Essential services like power, fuel, transportation, healthcare, communications and more are referre...

ENISA Threat Landscape 2024 - European Union - Seven prime cybersecurity threats were identified in 2024, with threats against availability topping...

The ENISA NIS Investments 2024 Report: A Cybersecurity ... - The ENISA NIS Investments 2024 report highlights a key trend: cybersecurity investments in the EU ar...